

POLITIQUE DE SECURITE MOBILE

Encadrement du développement et de l'usage des applications mobiles
Projet Sécurité Android – ESIEE-IT 2025/2026

Référence	POL-MOB-001
Version	1.0
Date d'émission	29 avril 2026
Statut	Applicable
Auteur	Équipe Sécurité – ESIEE-IT
Approbateur	Responsable Sécurité SI
Prochaine révision	Avril 2027

Document confidentiel – diffusion restreinte au personnel habilité

1. Objet et champ d'application

1.1 Objet

La présente politique de sécurité mobile (ci-après « la Politique ») définit les règles et exigences applicables au développement, au déploiement, à l'utilisation et à la maintenance des applications mobiles au sein de l'organisation. Elle vise à protéger les données des utilisateurs, à garantir l'intégrité des systèmes d'information et à assurer la conformité réglementaire.

Cette politique s'appuie sur les résultats de l'analyse statique de l'application Nickel (com.fpe.comptenickel, v2.12.0) réalisée avec MobSF, et intègre les enseignements tirés des vulnérabilités identifiées lors de ce projet académique.

1.2 Champ d'application

La Politique s'applique à :

- Toute application mobile (Android et iOS) développée en interne ou sous-traitée
- Toute application tierce déployée sur les équipements professionnels de l'organisation
- L'ensemble des équipements mobiles (smartphones, tablettes) utilisés dans un contexte professionnel, qu'ils soient fournis par l'organisation (COPE) ou personnels (BYOD)
- Tous les collaborateurs, prestataires, sous-traitants ayant accès aux systèmes d'information via un terminal mobile

1.3 Référentiels applicables

Cette politique s'inscrit dans le respect des référentiels et textes réglementaires suivants :

- OWASP Mobile Security Testing Guide (MSTG) & Mobile Application Security Verification Standard (MASVS)
- RGPD – Règlement Général sur la Protection des Données (UE 2016/679)
- ANSSI – Guide de sécurité des applications mobiles
- ISO/IEC 27001 – Systèmes de management de la sécurité de l'information
- PCI DSS v4.0 (pour les applications de paiement)
- Directive NIS2 (UE 2022/2555) pour les secteurs critiques

2. Rôles et responsabilités

La mise en œuvre de la présente politique implique les acteurs suivants :

Acteur	Responsabilités
Responsable Sécurité SI (RSSI)	Approbation et révision annuelle de la politique. Arbitrage des dérogations. Supervision des audits.
Équipe de développement mobile	Application des règles de développement sécurisé. Réalisation des tests de sécurité. Correction des vulnérabilités identifiées.
Équipe sécurité / pentest	Réalisation des audits de sécurité (SAST/DAST). Validation de la conformité avant mise en production. Veille sur les nouvelles menaces.
Administrateurs MDM	Configuration et maintien de la solution MDM. Application des politiques sur les terminaux. Gestion des incidents de conformité.

Acteur	Responsabilités
Utilisateurs finaux	Respect des règles d'usage. Signalement de tout comportement suspect. Participation aux formations de sensibilisation.
Direction / Management	Soutien et communication sur la politique. Allocation des ressources nécessaires. Validation des cas de dérogation majeurs.

3. Exigences de développement sécurisé

3.1 Gestion des versions et du SDK

SDK minimum : Toute application doit cibler un SDK Android minimum de 24 (Android 7.0) et iOS 14 minimum. Le support d'OS en fin de vie est interdit.

SDK cible : Les applications Android doivent cibler le SDK le plus récent disponible (targetSdk >= 34 à compter de 2025). Cela garantit l'application des politiques de sécurité modernes d'Android.

Justification issue de l'audit Nickel : L'application Nickel supporte Android 4.4 (minSdk=19), exposant les utilisateurs anciens à des centaines de CVE non corrigées. Cette configuration est prohibée par la présente politique.

3.2 Signature et intégrité du binaire

- Signature APK obligatoire avec le schéma v2 et v3 (la signature v1 seule est interdite)
- Utilisation d'un algorithme de signature SHA-256 minimum (SHA-1 est prohibé)
- Les clés de signature doivent être stockées dans un HSM ou un gestionnaire de secrets d'entreprise
- La signature v1 exclusivement est interdite car vulnérable à l'attaque Janus (CVE-2017-13156)
- Vérification de l'intégrité du binaire à chaque build via hash SHA-256 documenté

3.3 Chiffrement des communications

Toutes les communications réseau d'une application mobile doivent satisfaire les exigences suivantes :

- HTTPS obligatoire pour toute communication réseau – le trafic HTTP en clair (cleartext) est strictement interdit
- Mise en place d'un Network Security Config Android restrictif : usesCleartextTraffic="false"
- Certificate Pinning obligatoire pour les applications financières et les APIs critiques
- TLS 1.2 minimum – TLS 1.3 recommandé. SSLv3, TLS 1.0 et TLS 1.1 sont prohibés
- Validation stricte des certificats côté client – pas de validation personnalisée bypassant les vérifications standard

Justification issue de l'audit Nickel : L'application Nickel autorise le trafic cleartext (usesCleartextTraffic=true), exposant les utilisateurs sur Wi-Fi public à des attaques MITM. Cette configuration est strictement prohibée.

3.4 Stockage des données sensibles

- Aucune donnée sensible (identifiants, tokens, données bancaires) ne doit être stockée en clair dans SharedPreferences, SQLite sans chiffrement, ou sur le stockage externe
- Utilisation obligatoire de l'Android Keystore System pour stocker les clés cryptographiques

- Les logs de débogage ne doivent contenir aucune donnée personnelle ou sensible en production
- La permission `WRITE_EXTERNAL_STORAGE` doit être justifiée fonctionnellement et limitée au strict nécessaire
- Activation du flag `android:allowBackup="false"` sauf besoin explicitement documenté et sécurisé

3.5 Gestion des permissions

Le principe du moindre privilège s'applique à toutes les permissions Android/iOS :

- Déclaration uniquement des permissions strictement nécessaires au fonctionnement de l'application
- Les permissions `DANGEROUS` doivent faire l'objet d'une justification fonctionnelle documentée
- Demande de permissions au moment de l'usage (runtime permissions) et non au démarrage
- Utilisation des APIs modernes : `USE_BIOMETRIC` au lieu de `USE_FINGERPRINT` (dépréciée depuis API 28)
- Revue des permissions à chaque release pour identifier les permissions devenues inutiles

Permission sensible	Niveau de risque	Exigence
<code>READ_CONTACTS / WRITE_CONTACTS</code>	DANGEROUS	Justification documentée obligatoire + consentement utilisateur explicite
<code>WRITE_EXTERNAL_STORAGE</code>	DANGEROUS	Usage limité au strict nécessaire, migration vers MediaStore API pour Android 10+
<code>CAMERA / RECORD_AUDIO / LOCATION</code>	DANGEROUS	Demande à l'usage uniquement – révocable à tout moment par l'utilisateur
<code>USE_FINGERPRINT</code>	INTERDIT	API dépréciée – remplacer obligatoirement par <code>USE_BIOMETRIC</code>

3.6 Composants exportés et surface d'attaque

- Tout composant Android (Activity, Service, BroadcastReceiver, ContentProvider) doit avoir `android:exported="false"` par défaut
- Les composants exportés doivent être protégés par une permission `android:protectionLevel="signature"` au minimum
- Les intent-filters exposant un Service sans protection sont interdits
- Les ContentProviders exportés doivent implémenter une vérification d'accès
- Revue systématique du manifeste Android par l'équipe sécurité avant chaque release majeure

3.7 Bibliothèques natives et tierces

- Activation obligatoire de `FORTIFY_SOURCE=2` dans les flags de compilation de tous les modules natifs (CMakeLists.txt ou Android.mk)
- Les protections mémoire NX, PIE, Stack Canary et Full RELRO doivent être activées sur toutes les bibliothèques partagées

- Inventaire et suivi de version de toutes les dépendances tierces (Software Bill of Materials – SBOM)
- Mise à jour régulière des dépendances – pas de bibliothèque abandonnée ou sans support actif
- Analyse automatique des dépendances pour les CVE connues (OWASP Dependency-Check ou équivalent)

3.8 Intégration de trackers et SDK tiers

L'intégration de SDK tiers (analytics, crash reporting, publicité, notifications) est soumise aux règles suivantes :

- Toute intégration de SDK tiers doit faire l'objet d'une analyse de sécurité préalable
- Les données collectées par les SDK tiers doivent être limitées au strict nécessaire (minimisation)
- Les SDK dont les serveurs sont localisés hors EEE doivent faire l'objet d'une DPIA (Data Protection Impact Assessment) RGPD
- La liste des trackers doit être déclarée dans la politique de confidentialité de l'application
- Les SDK de type Pushwoosh hébergés hors UE doivent être évalués quant à leur conformité au RGPD avant tout déploiement en production

4. Exigences d'audit et de test de sécurité

4.1 Analyse statique (SAST)

- Analyse statique obligatoire via MobSF (ou outil équivalent) sur chaque release candidate
- Score de sécurité MobSF minimum requis : 70/100 pour les applications grand public, 80/100 pour les applications financières
- Aucune vulnérabilité HIGH ou CRITIQUE non traitée ne peut être mise en production
- Le rapport SAST doit être archivé et versé au dossier de sécurité de l'application

4.2 Analyse dynamique (DAST)

- Analyse dynamique obligatoire au moins une fois par an et avant toute release majeure
- Tests de pénétration mobile conformes à la méthodologie OWASP MSTG
- Environnement de test isolé du SI de production
- Résultats documentés avec reproduction des vulnérabilités et preuves (captures d'écran, requêtes réseau)

4.3 Pipeline CI/CD sécurisé

Pour les équipes pratiquant le DevSecOps, les contrôles de sécurité suivants doivent être intégrés dans la chaîne CI/CD :

1. Analyse statique du code source (SonarQube, Semgrep ou équivalent)
2. Analyse des dépendances (OWASP Dependency-Check)
3. Analyse du binaire APK/IPA avant déploiement (MobSF API)
4. Vérification de la signature du binaire
5. Notification automatique de l'équipe sécurité en cas d'anomalie

4.4 Gestion des vulnérabilités

Les délais maximaux de remédiation selon la criticité sont les suivants :

Criticité	Délai de correction	Action immédiate
CRITIQUE	48 heures maximum	Retrait de l'application du store si nécessaire
HAUTE	7 jours maximum	Notification RSSI – plan de remédiation sous 24h
MOYENNE	30 jours	Intégration dans la prochaine release planifiée
BASSE	90 jours	Backlog sécurité – priorisation selon le risque

5. Politique d'usage des terminaux mobiles

5.1 Terminaux fournis par l'organisation (COPE)

- Installation d'un agent MDM obligatoire avant remise à l'utilisateur
- Chiffrement du stockage activé (BitLocker/FileVault/chiffrement Android natif)
- Verrouillage automatique après 5 minutes d'inactivité
- Code PIN minimum 6 chiffres ou authentification biométrique
- Mise à jour automatique du système d'exploitation activée
- Installation d'applications limitée au store d'entreprise ou au Play Store / App Store officiels
- Sideload d'APK interdit sauf dérogation RSSI documentée
- Root / Jailbreak entraînant la révocation immédiate de l'accès aux ressources SI

5.2 Terminaux personnels (BYOD)

L'accès aux ressources de l'organisation depuis un terminal personnel est soumis à l'installation d'un profil MDM dédié, dans un conteneur applicatif isolé des données personnelles. Les exigences suivantes s'appliquent :

- Installation obligatoire du profil MDM BYOD avant tout accès aux données de l'organisation
- Le profil MDM est limité au conteneur professionnel – aucune surveillance des données personnelles
- OS non patché (> 3 mois de retard) : accès restreint aux seules applications non sensibles
- Root / Jailbreak détecté : accès immédiatement bloqué jusqu'à remise en conformité
- Départ de l'organisation : effacement à distance du conteneur professionnel uniquement

5.3 Règles d'usage communes

- Connexion aux réseaux Wi-Fi publics non chiffrés interdite sans VPN d'entreprise actif
- Interdiction d'installer des applications provenant de sources non officielles (APK tiers, Cydia...)
- Signalement obligatoire de tout terminal perdu ou volé dans les 2 heures suivant la constatation
- Interdiction d'utiliser des applications de partage de fichiers grand public (WhatsApp, Telegram perso) pour transmettre des données professionnelles

- Les applications mobiles professionnelles ne doivent pas être utilisées sur des terminaux rootés ou jailbreakés

6. Exigences pour les services cloud intégrés

6.1 Firebase et bases de données cloud

- Les règles de sécurité Firebase doivent interdire tout accès public en lecture/écriture
- Révision des règles Firebase obligatoire à chaque modification du modèle de données
- Les clés de configuration Firebase Remote Config ne doivent pas contenir d'informations sensibles susceptibles d'être extraites du binaire
- Test d'accès public obligatoire avant chaque mise en production : GET `/[project].firebaseio.com/.json` doit retourner une erreur 401
- Les données Firebase de production ne doivent pas transiter via des clés de développement

6.2 Localisation des données et conformité RGPD

- Les données à caractère personnel des utilisateurs européens doivent être hébergées au sein de l'EEE ou dans des pays bénéficiant d'une décision d'adéquation de la Commission européenne
- Tout transfert hors EEE doit faire l'objet d'une DPIA et de garanties appropriées (clauses contractuelles types)
- La localisation géographique des serveurs contactés par l'application doit être documentée et revue annuellement
-

7. Gestion des dérogations

Toute dérogation aux exigences de la présente politique doit suivre la procédure suivante :

6. Rédaction d'une demande de dérogation documentant la règle concernée, la raison de la dérogation et les mesures compensatoires envisagées
7. Analyse de risque associée à la dérogation
8. Validation par le RSSI et le responsable applicatif
9. Durée limitée de la dérogation (12 mois maximum, renouvelable)
10. Inscription dans le registre des dérogations et suivi trimestriel

Les dérogations suivantes sont strictement interdites et ne peuvent faire l'objet d'aucune exception :

- Stockage de données bancaires ou de mots de passe en clair
- Désactivation totale du chiffrement des communications
- Déploiement d'une application avec une vulnérabilité CRITIQUE connue non traitée

8. Sensibilisation et formation

La sécurité mobile repose sur la conscience de l'ensemble des acteurs. Les actions de formation suivantes sont obligatoires :

Public cible	Formation requise	Fréquence
Développeurs mobile	Développement sécurisé Android/iOS (OWASP MASVS)	Initiale + mise à jour annuelle
Équipe sécurité	Analyse statique et dynamique d'APK (MobSF, Frida, Burp)	Annuelle
Administrateurs MDM	Configuration et gestion MDM – gestion de flotte mobile	À la prise de poste + annuelle
Tous les utilisateurs	Sensibilisation aux risques mobiles (hameçonnage, Wi-Fi public, applications malveillantes)	Annuelle (e-learning 30 min)

9. Contrôle, indicateurs et révision

9.1 Indicateurs de conformité (KPI)

Les indicateurs suivants sont mesurés et reportés trimestriellement au RSSI :

Indicateur	Cible	Source
Score MobSF moyen des applications en prod	>= 70/100 (fin. >= 80)	Rapports SAST
% applications avec vulnérabilités CRITIQUES ouvertes	0 %	Tracker vulnérabilités
Délai moyen de remédiation des vuln. HIGH	<= 7 jours	Tracker vulnérabilités
% terminaux MDM conformes à la politique	>= 95 %	Console MDM
% utilisateurs ayant suivi la sensibilisation annuelle	>= 90 %	LMS
Délai de signalement terminal perdu/volé	<= 2 heures	Registre incidents

9.2 Révision de la politique

La présente politique est révisée selon le calendrier et les déclencheurs suivants :

- Révision annuelle systématique (chaque avril)
- Révision déclenchée en cas d'incident de sécurité mobile majeur
- Révision lors de l'adoption d'une nouvelle technologie ou plateforme mobile
- Révision en cas d'évolution réglementaire significative (RGPD, NIS2, DSP3...)
- Révision lors de tout changement organisationnel majeur (fusion, acquisition, restructuration)

10. Non-conformité et sanctions

Le non-respect de la présente politique peut entraîner les conséquences suivantes, proportionnelles à la gravité des manquements :

Type de manquement	Sanction applicable	Procédure
Non-respect involontaire (méconnaissance)	Rappel à l'ordre + formation obligatoire	Entretien avec le manager et le RSSI
Non-respect répété ou délibéré	Restriction d'accès aux ressources SI + avertissement	Procédure RH formelle
Violation grave (mise en danger SI / données)	Suspension d'accès immédiate + sanctions disciplinaires	Direction + service juridique

Pour les prestataires et sous-traitants, le non-respect de la politique constitue une violation contractuelle pouvant entraîner la résiliation du contrat conformément aux clauses de sécurité applicables.

Annexe A – Checklist sécurité avant mise en production

Cette checklist doit être complétée et signée par le responsable technique avant toute mise en production d'une application mobile. Elle constitue la preuve de conformité à la présente politique.

#	Point de contrôle	Conforme	N/A
1	minSdk >= 24 (Android 7.0) – targetSdk >= dernière version stable	☐	☐
2	Signature APK v2 et/ou v3 activée – signature v1 désactivée	☐	☐
3	Algorithme SHA-256 utilisé pour la signature (pas SHA-1)	☐	☐
4	usesCleartextTraffic="false" ou Network Security Config restrictif	☐	☐
5	Certificate Pinning implémenté pour les APIs critiques	☐	☐
6	Aucune donnée sensible en clair dans les logs, SharedPreferences, ou stockage externe	☐	☐
7	Permissions DANGEROUS justifiées et limitées au strict nécessaire	☐	☐
8	USE_FINGERPRINT remplacé par USE_BIOMETRIC	☐	☐
9	Composants exportés protégés par une permission ou exportés=false	☐	☐
10	FORTIFY_SOURCE=2 activé dans le build system natif	☐	☐
11	Inventaire des SDK tiers et vérification RGPD réalisée	☐	☐
12	Règles Firebase testées – pas d'accès public	☐	☐
13	Score MobSF >= 70/100 (ou >= 80/100 pour les apps financières)	☐	☐
14	Aucune vulnérabilité CRITIQUE ou HIGH ouverte	☐	☐
15	Rapport SAST archivé dans le dossier de sécurité	☐	☐

#	Point de contrôle	Conforme	N/A
16	Test de régression fonctionnel sur les correctifs de sécurité	☐	☐

Responsable technique : _____ Date : _____
Signature : _____

Historique des versions

Version	Date	Auteur	Modifications
1.0	29/04/2026	Équipe Sécurité ESIEE-IT	Création initiale – basée sur l'audit MobSF de l'application Nickel

— Fin du document —